Security risk assessment report

Part 1: Select up to three hardening tools and methods to implement
1. Multifactor Authentication (MFA) **2. Password Policies** **3. Firewall Maintenance**

Part 2: Explain your recommendations
1**. Multifactor Authentication (MFA)** • **Why it is effective:** MFA requires users to provide two or more verification factors (e.g., a password and a one-time code sent to their phone) to access a system. This directly addresses the vulnerability of the missing MFA in the organization. Even if an employee shares a password or an attacker successfully guesses the default admin password, they cannot access the network or database without the second factor. • **How often to implement:** MFA is typically a "set up once and maintain" technique. The initial setup is done once, but it should be reviewed regularly (e.g., annually) to ensure it is enforced across all critical systems and that users are not bypassing it. **2. Password Policies** • **Why it is effective:** Implementing strict password policies using NIST guidelines (salting and hashing) prevents attackers from easily guessing passwords. It addresses two vulnerabilities: it prevents users from sharing passwords and forces the immediate change of the default database admin password to a complex, unique one. • **How often to implement:** Password policies are enforced continuously by the system. However, they should be reviewed

every few months (e.g., quarterly) to ensure they align with current security standards and to check for compromised credentials.

3. Firewall Maintenance

- **Why it is effective:** Updating and maintaining firewall rules (including port filtering) ensures that only authorized traffic can enter and leave the network. This addresses the vulnerability of having no traffic filtering rules. By blocking unused ports and filtering abnormal traffic, the organization prevents malicious actors from exploiting open entry points.
- **How often to implement:** Firewall maintenance should be performed **regularly** (e.g., weekly or monthly). It must also be done immediately in response to a security event or an alert from the network log analysis tool (SIEM) to block active threats.